

CASA Evidence — OWASP Dependency-Check Scan

CASA Evidence — OWASP Dependency-Check Scan

Question: *Provide output of a dependency scan of application and 3P libraries using OWASP Dependency-Check or other ADA-approved scanning tools.*

Application: Provenance (Next.js App Router monorepo, pnpm workspace, Supabase backend).

Scan date: 2026-07-31 (initial scan) → 2026-07-31 (remediated, zero active findings) → 2026-08-03 (re-verified against a refreshed NVD database, zero active findings, zero critical/high)

1. Scanning tool

Field	Value
Tool	OWASP Dependency-Check
Version	12.2.2 (<code>dependency-check --version</code>)
Install method	Homebrew (<code>brew install dependency-check</code>)
CVE data source	NVD API (372,261 records updated at scan time) + CISA KEV list
Analyzers used	Node Package Analyzer, Pnpm Audit Analyzer , RetireJS, NVD CVE Analyzer, Known Exploited Vulnerability Analyzer

OWASP Dependency-Check is an OWASP Foundation project that correlates project dependencies against the National Vulnerability Database (NVD) and ecosystem-specific advisory feeds (npm/pnpm audit, RetireJS, etc.).

2. Scope

The scan covers the **entire Provenance monorepo**, including:

- Root application (`package.json` , `pnpm-lock.yaml`)
- Workspace packages under `packages/*`

- Apps under `apps/*` (collectibles, API, etc.)
- Makerkit starter packages actually consumed by the app, under `makerkit/nextjs-saas-starter-kit-lite/packages/**` and `tooling/*`

Lockfile: `pnpm-lock.yaml` (pnpm v10.19.0) — single source of truth for resolved third-party library versions across all workspaces.

Excluded from filesystem walk:

- Non-dependency paths: `node_modules/`, `.git/`, `.next/`, `.pnpm-store/`, binary assets (images, PDFs, blend files), and `neon-hyrule/` demo assets.
 - `makerkit/nextjs-saas-starter-kit-lite/package.json`, `pnpm-lock.yaml`, `turbo.json`, and `apps/**` — this is the vendored, upstream MakerKit starter-kit reference copy. Its `packages/**` and `tooling/*` subfolders **are** real workspace members consumed by the deployed app (declared in `pnpm-workspace.yaml` and pulled in via `workspace:*` deps such as `@kit/ui`, `@kit/auth`, `@kit/accounts`), so those remain in scope. Its own root project and `apps/web` / `apps/provenance` / `apps/e2e` subfolders are **not** part of the pnpm workspace (`pnpm-workspace.yaml` only globs `makerkit/nextjs-saas-starter-kit-lite/packages/**` and `tooling/*`), have their own local, gitignored `node_modules`, and are never built or deployed — they are excluded to avoid scanning unused reference code as if it were shipped software.
-

3. Command executed

```
cd /Users/timothylefkowitz/projects/provenance

dependency-check \
  --project "Provenance" \
  --scan . \
  -f HTML -f JSON -f XML -f JUNIT -f SARIF \
  --prettyPrint \
  -o docs/casa-evidence/dependency-check \
  --noupdate \
  --suppression docs/casa-evidence/dependency-check-suppressions.xml \
  --exclude "**/node_modules/**" \
  --exclude "**/.git/**" \
  --exclude "**/.next/**" \
  --exclude "**/neon-hyrule/**" \
  --exclude "**/.pnpm-store/**" \
  --exclude "**/*.blend*" \
  --exclude "**/*.png" \
  --exclude "**/*.jpg" \
  --exclude "**/*.pdf" \
  --exclude "**/*.ptx" \
  --exclude "**/makerkit/nextjs-saas-starter-kit-lite/pnpm-lock.yaml" \
  --exclude "**/makerkit/nextjs-saas-starter-kit-lite/package.json" \
  --exclude "**/makerkit/nextjs-saas-starter-kit-lite/turbo.json" \
  --exclude "**/makerkit/nextjs-saas-starter-kit-lite/apps/**"
```

Exit code: **0** (scan completed successfully).

4. Summary results

Before remediation

Metric	Count
Total dependencies analyzed	157
Dependencies with known vulnerabilities	29
Total vulnerability findings	31
Critical	1
High	18
Moderate / Medium	8
Low	4

Raw output preserved for audit trail under `docs/casa-evidence/dependency-check-before/`.

After remediation (2026-07-31)

Metric	Count
Total dependencies analyzed	113
Active vulnerability findings	0
Documented suppressions (verified false positives)	2

All 29 vulnerable dependencies were resolved by upgrading to patched versions. The remaining 2 findings are suppressed with a documented, auditable justification (see §6) rather than silently ignored — both were manually verified to not be exploitable in this codebase.

Re-verification against refreshed NVD data (2026-08-03, current state)

Before re-scanning, the local NVD/CVE cache was refreshed (`dependency-check --updateonly` , pulling 1,175 new/updated advisory records) to catch anything newly published in the ~3 days since the initial remediation, then the full scan (§3) was re-run unchanged.

Metric	Count
Total dependencies analyzed	112
Active vulnerability findings	0
Critical / High severity findings	0
Documented suppressions (verified false positives)	1

Result: **no critical or high severity vulnerabilities**, and no active findings of any severity. The `brace-expansion` suppression (GHSA-mh99-v99m-4gvg) is now a no-op — Dependency-Check logged `Suppression Rule had zero matches` for it, meaning the underlying advisory-matching data has caught up and no longer misflags the already-patched version. The rule is left in place (harmless if unused) in case that matching regresses in a future scan. Only the `leaflet` suppression (§6) is currently active.

5. Remediation actions taken

Package	Before	After	Advisory fixed
<code>next</code> (root + all workspace apps/packages)	15.5.9	15.5.22	GHSA-492v-c6pp-mqqv, GHSA-26hh-7cqf-hhc6 (middleware bypass), plus bundled <code>sharp</code> /React CVEs
<code>sharp</code>	0.35.2	0.35.3	GHSA-f88m-g3jw-g9cj (libvips)

Package	Before	After	Advisory fixed
<code>vitest</code> (devDependency)	3.2.4	3.2.7	GHSA-5xrq-8626-4rwp — Critical , UI/API server path traversal
<code>turbo</code> (added as direct devDependency to pin resolution)	2.5.8	2.10.8	GHSA-hcf7-66rw-9f5r (CSRF), GHSA-3qcw-2rhx-2726 (code exec via Yarn detection)
<code>ws</code>	8.18.3	8.21.1	GHSA-58qx-3vcg-4xpx, GHSA-96hv-2xvq-fx4p (memory exhaustion)
<code>vite</code>	7.3.3	7.3.5	GHSA-fx2h-pf6j-xcff (Windows <code>server.fs.deny</code> bypass)
<code>brace-expansion</code>	1.1.12 / 2.0.2	1.1.17 / 2.1.3	GHSA-mh99-v99m-4gvq (DoS) — see suppression note, §6
<code>@babel/core</code>	7.28.5	7.29.6	GHSA-4x5r-pxfx-6jf8
<code>@xmldom/xmldom</code>	0.8.11	0.8.13	GHSA-x6wf-f3px-wcqx and related XML injection/DoS advisories
<code>ajv</code>	6.12.6	6.14.0	GHSA-2g4f-4pwh-qvx6
<code>esbuild</code>	0.27.7	0.28.1	GHSA-g7r4-m6w7-qqqr
<code>flatted</code>	3.3.3	3.4.4	GHSA-rf6f-7fwh-wjgh
<code>form-data</code>	4.0.5	4.0.6	GHSA-hmw2-7cc7-3qxx
<code>js-yaml</code>	4.1.0	4.3.0	GHSA-52cp-r559-cp3m
<code>lodash</code>	4.17.21	4.18.1	GHSA-r5fr-rjxr-66jc
<code>minimatch</code>	3.1.2 / 9.0.5	3.1.4 / 9.0.7	GHSA-3ppc-4f35-3m26
<code>picomatch</code>	2.3.1 / 4.0.3	2.3.2 / 4.0.5	GHSA-c2c7-rcm5-vvqj
<code>postcss</code>	8.4.31 / 8.5.6	8.5.25	GHSA-r28c-9q8g-f849
<code>qs</code>	6.15.0	6.15.2	GHSA-q8mj-m7cp-5q26
<code>tar</code>	7.5.1	7.5.22	GHSA-34x7-hfp2-rc4v

Mechanism: pinned via `pnpm.overrides` in the root `package.json` (with selective `name@majorRange` overrides for packages resolved at multiple major versions in the tree), plus direct version bumps for `next`, `sharp`, and `vitest`, and adding `turbo` as an explicit devDependency so its peer-resolved copy (previously pulled in transitively at an old version by `eslint-config-turbo`) also picks up the patched version. `pnpm install` / `pnpm dedupe` regenerated `pnpm-lock.yaml`.

`uuid`, `ip-address`, `@turbo/workspaces`, `diff`, `tmp`, `basic-ftp`, `handlebars`, and a stray `react@19.2.1` from the original report were sourced entirely from the vendored, gitignored, un-deployed MakerKit reference project (`apps/web`, `apps/provenance`, `apps/e2e`, and the vendor project's own root `node_modules/lockfile` described in §2) — not from the real dependency graph. These are resolved by the scope exclusion in §2/§3 rather than a version bump, since there is no such package installed in the deployed application.

Validation performed after remediation: `pnpm typecheck` (same 90 pre-existing, unrelated type errors before and after — confirmed via side-by-side comparison on the pre-upgrade lockfile), `pnpm test:unit` (14/14 passing), and `pnpm build` (`next build`, production build succeeds) were all run after the dependency bumps to confirm no regressions.

6. Suppressed findings (documented false positives)

Suppression file: `docs/casa-evidence/dependency-check-suppressions.xml`

Package	Advisory	Justification
<code>leaflet@1.9.4</code>	CVE-2025-69993 (XSS via <code>bindPopup</code> string HTML rendering)	Leaflet's maintainers have published a formal statement (Leaflet/Leaflet#10214) that this is intended, documented API behavior, not a library defect, and there is no patched release. Provenance never calls Leaflet's raw <code>bindPopup(string)</code> HTML API — the only usage (<code>src/app/artworks/[id]/certificate/_components/scan-locations-map.tsx</code>) is via <code>react-leaflet</code> 's <code><Popup></code> component, which renders content as React children that React auto-escapes. The vulnerable sink is unreachable from this codebase.

Package	Advisory	Justification
brace-expansion	GHSA-mh99-v99m-4gvg / CVE-2026-14257 (DoS via unbounded expansion length)	pnpm-lock.yaml resolves brace-expansion to 1.1.17 and 5.0.9, both explicitly listed in the upstream advisory's own "Patched versions" (1.1.17, 2.1.3, 3.0.3, 5.0.8+). Verified directly via grep -n "^ brace-expansion@" pnpm-lock.yaml . Dependency-Check's local Pnpm Audit Analyzer did not resolve this finding down to the specific installed version and flagged the package name generically as of the 2026-07-31 scan — a known tool/data-matching limitation, not an unpatched dependency. Update (2026-08-03): after refreshing the local NVD/advisory cache, this finding no longer appears at all (Suppression Rule had zero matches). The suppression rule is left in place in case the matching issue recurs in a future scan.

Both suppressions are scoped narrowly (specific package + specific CVE/GHSA ID), documented with the verification steps used, and should be re-evaluated if the advisory scope, Leaflet's usage in this codebase, or Dependency-Check's matching logic changes.

7. Raw scan output (for auditor review)

All files generated by OWASP Dependency-Check and committed under

docs/casa-evidence/dependency-check/ (latest re-verification scan, 2026-08-03, zero active findings, zero critical/high) and docs/casa-evidence/dependency-check-before/ (original pre-remediation scan from 2026-07-31, preserved as an audit trail):

File	Format	Purpose
dependency-check-report.html	HTML	Human-readable interactive report (primary reviewer artifact)
dependency-check-report.json	JSON	Machine-readable full report
dependency-check-report.xml	XML	CI/integration format
dependency-check-junit.xml	JUnit	CI test-result format
dependency-check-report.sarif	SARIF	Static-analysis tool interchange format

To reproduce locally:

```
brew install dependency-check
cd /path/to/provenance
# run command from §3
open docs/casa-evidence/dependency-check/dependency-check-report.html
```

8. Scan limitations & notes

1. **pnpm monorepo:** Dependency-Check emitted warnings for workspace `package.json` files without per-package lockfiles; resolution is anchored on the root `pnpm-lock.yaml` via the Pnpm Audit Analyzer. This is expected for pnpm workspaces.
2. **Excluded apps:** `apps/realstate` and `apps/vehicles` are excluded from the pnpm workspace (`pnpm-workspace.yaml`) and had incomplete `node_modules`; they are not part of the deployed Provenance app. Their `next` version was still bumped to 15.5.22 for consistency, in case they are activated in the future.
3. **Vendored reference code:** see §2 for the MakerKit starter-kit scope exclusion rationale.
4. **NVD API key:** Scan ran without an NVD API key; initial CVE database download took ~48 minutes. Subsequent scans use `--noupdate` against the local NVD cache populated by that initial run, or set `--nvdApiKey` for faster updates.

9. Ongoing remediation process

When Dependency-Check (or CI equivalent) reports new findings:

1. Triage by severity and whether the package is in the **production runtime** dependency tree vs. dev/build-only.
2. Upgrade affected packages via `pnpm update` / targeted version bumps in `package.json`, or add/adjust a `pnpm.overrides` entry, then regenerate `pnpm-lock.yaml` (`pnpm install`, `pnpm dedupe`).
3. Re-run `pnpm typecheck`, `pnpm test:unit`, and `pnpm build` to confirm no regressions before shipping the bump.
4. Re-run Dependency-Check and attach updated reports to this evidence folder (keep the prior report as a `-before` snapshot for audit history).
5. For accepted risks or verified false positives, document rationale in `docs/casa-evidence/dependency-check-suppressions.xml` with a narrowly-scoped `<suppress>` rule (specific package + specific CVE/GHSA ID) rather than a blanket suppression, and record the justification in §6 of this document.